



PDF Download
2414456.2414513.pdf
23 March 2026
Total Citations: 31
Total Downloads: 510

Latest updates: <https://dl.acm.org/doi/10.1145/2414456.2414513>

RESEARCH-ARTICLE

PassMap: a map based graphical-password authentication system

HUNG-MIN SUN, National Tsing Hua University, Hsinchu, Taiwan

YAO-HSIN CHEN, National Tsing Hua University, Hsinchu, Taiwan

CHIUNG-CHENG FANG, National Tsing Hua University, Hsinchu, Taiwan

SHIH-YING CHANG, National Tsing Hua University, Hsinchu, Taiwan

Open Access Support provided by:

National Tsing Hua University

Published: 02 May 2012

Citation in BibTeX format

ASIA CCS '12: 7th ACM Symposium
on Information, Computer and
Communications Security
May 2 - 4, 2012
Seoul, Korea

Conference Sponsors:
SIGSAC

PassMap: A Map Based Graphical-Password Authentication System

Hung-Min Sun
Department of Computer
Science, National Tsing Hua
University, Hsinchu, Taiwan
hmsun@cs.nthu.edu.tw

Yao-Hsin Chen
Department of Computer
Science, National Tsing Hua
University, Hsinchu, Taiwan
yaohsin.chen@is.cs.
nthu.edu.tw

Chiung-Cheng Fang
Department of Computer
Science, National Tsing Hua
University, Hsinchu, Taiwan
ccfang@is.cs.nthu.edu.tw

Shih-Ying Chang
Department of Computer
Science, National Tsing Hua
University, Hsinchu, Taiwan
godspeed@is.cs.nthu.edu.tw

ABSTRACT

Text passwords have been used in authentication systems for many decades. Users must recall the textual strings selected during registration to pass authentication. However, there are some serious problems with text passwords—recollection and security. Hence, various graphical-password authentication systems have been proposed to solve the problems of text passwords. Previous studies indicate that humans are better at recognizing and recalling images than texts. In 2005, Wiedenbeck et al. proposed PassPoints in which a password consists of a sequence of click-points (5 to 8) that a user chooses on an image. In the paper, we proposed an alternative system in which users can memorize fewer points while providing more security than PassPoints. Based on the idea of using an extremely large image as the password space, we propose a novel world map based graphical-password authentication system called PassMap in which a password consists of a sequence of 2 click-points that a user selects on an large world map. We also conducted a user study for evaluation. The result shows that the passwords of PassMap are easy to memorize for humans and PassMap is friendly to use in practice. Furthermore, PassMap provides higher entropy than PassPoints and also increases the cost of attacks.

Categories and Subject Descriptors

K.6.5 [Security and Protection]: Authentication

Keywords

Authentication; Graphical Passwords

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. To copy otherwise, to republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee.

ASIACCS '12, May 2–4, 2012, Seoul, Korea.

Copyright 2012 ACM 987-1-4503-1303-2/12/05 ...\$10.00.

1. INTRODUCTION

Text passwords have been used in authentication systems over the past few decades. Users must recall the textual strings selected during registration to pass the authentication. However, there are some serious problems with text passwords. First, users are not experts in memorizing textual strings, especially strong passwords. Second, in order to overcome the first problem, most users will choose easy-to-remember or meaningful textual strings as passwords, and these passwords are weak.

Hence, various graphical-password authentication systems have been proposed to solve the problems of text passwords [1, 9, 5, 8, 10, 13], based on previous studies which indicated that humans are better at recognizing and recalling images than texts [7, 3]. In 2005, Wiedenbeck et al. proposed PassPoints [12] in which a password consists of a sequence of click-points (5 to 8) that user chooses in an image. PassPoints is a well-known and highly discussed graphical-password system. Graphical passwords not only reduce the users' burden of recollection, but also provide a larger password space, improving both the security and the usability of authentication systems.

However, we think that it is still difficult to memorize PassPoints passwords, especially when images are provided by a server. Thus, we designed an alternative system in which users can memorize fewer points, while providing more security than PassPoints.

Based on the idea of using extremely large images as the password space, we propose a novel world map based graphical-password authentication system called PassMap to solve the password recollection and password security weaknesses of PassPoints. In PassMap, a password consists of a sequence of 2 click-points that the user selects on a large world map. We also conducted a user study for evaluation.

2. PROBLEM STATEMENT, ATTACK MODEL AND ASSUMPTIONS

2.1 Problem Statement

The idea of PassMap is to use an extremely huge images as the password space. However, this idea has some prob-

lems in practice. First, the display size of normal devices is limited so the displays cannot show a whole image, and users must drag the image to find their points. This may be time-consuming and inconvenient. Second, it is difficult for users to memorize points when using extremely huge images even fewer points should be selected. Therefore, we want to solve the problems of: 1) password recollection and password security of PassPoints; 2) using extremely huge images as the password space in graphical-password authentication systems.

2.2 Attack Model

We model the threats faced in graphical-password authentication systems. Attacks are classified as brute force and pattern dictionary attacks.

Brute Force Attacks The attackers can try all elements in the password space, by imitating the clicking or other actions of mouses. If time and processing power are unlimited, attackers can find all possible passwords. However, it is constrained in practice by time, computing power and password space size.

Pattern Dictionary Attacks Based on previous researches [4, 11], users' choices are predictable in most cued-recall based systems [2], so attackers can make use of this property. Attackers first collect images used by authentication systems, then process and analyze the images to obtain the hotspots and patterns. Hotspots are the points or areas of an image that has a higher probability to be chosen by users as click-points, and patterns are the shapes composed of click-points of an image in a password. Hence, attackers can try all hotspots or patterns with higher probability to crack the authentication systems.

2.3 Assumptions

In this study, we have two assumptions. First, we assume that any communication of our authentication system is protected using SSL (Secure Socket Layer), so packets or information are not eavesdropped or intercepted by attackers in the transmissions. Second, we assume that the computers or devices in our authentication system are trusted. This means that the devices are not affected by malicious softwares, e.g., viruses, worms, or Trojan horse softwares. These malicious softwares may record keyboard inputs, capture mouse actions, record screen shots or exploit software vulnerabilities to bypass the authentication. This assumption is the basis of most authentication systems.

3. THE PROPOSED SCHEME

We propose a graphical-password authentication system called PassMap to solve password recollection and password security of PassPoints. In PassMap, a password consists of a sequence of 2 click-points that a user selects in a huge world map. Fig. 1 shows a possible password pair in which the first click-point (red point) is nearby Taipei 101 and the second click-point (red point) is at New York Central Park. We use an extremely huge image as our password space; hence, users can memorize fewer click-points, and the password space is much larger than PassPoints.

The world map has various zoom levels, showing various contents and information of different levels. Fig. 2 is an example. With high zoom levels, a whole world map is a huge image; with low zoom levels, an image of world map

is relatively small. Hence, we can advanced place the world map with moderate size and lower zoom levels in displays of devices, so users can drag or move the map to some selected areas quickly, then zooming up the map. Repeating these actions until the image of world map is huge enough as a password space and choosing the click-points from that. Furthermore, compared to the arbitrary images, humans have their own feelings or memories about some positions on the world map, e.g., their home, old schools, somewhere they traveled or scenic spots. Hence, even on the lower zoom levels, users can arrive at selected areas quickly and accurately in password space by dragging and zooming, and they can memorize the click-points more easily in this password space.

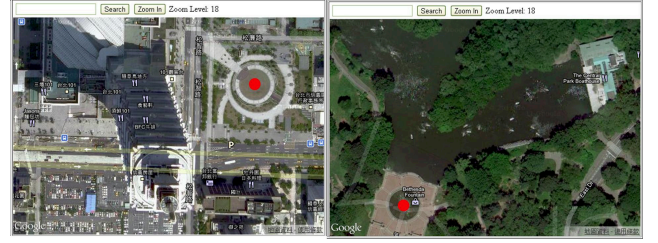


Figure 1: A password in PassMap authentication system. First click-point (red point) is nearby Taipei 101, and second one (red point) is at New York Central Park.



Figure 2: Various contents and information of world map with different zoom levels.

3.1 PassMap

In PassMap graphical-password authentication system, there are two usage phases: the registration phase and the login phase. We will describe the procedure of these two phases in details and discuss password resetting later.

Registration Phase In this phase, users will create their PassMap accounts and passwords. They will need to use these credentials to login later. The following is the complete procedure:

1. User inputs his account and other specific personal information, e.g., name, age, e-mail, into the graphical user interfaces provided by PassMap.
2. Then, the user can shift the world map to selected areas, and zoom the map to the desired zoom level. Finally, he chooses 2 points as his passwords. User can zoom out on the map for re-selection or search some places directly via the search function.

3. Next is password confirmation. A user repeats step 2 to try to find the 2 points that he selected in the first time. If the confirmation fails, this registration will be terminated.
4. PassMap discretizes the world map at the beginning of the phase, then records the discretized information of the click-points selected in step 2 and 3, i.e., safe tolerance squares and corresponding grids, and hashes this data representing click-points as the password.
5. Finally, PassMap stores the account, the hashed password and other personal information in the database. This completes the registration phase.

Login Phase In this phase, users use accounts and passwords created during the registration phase to log into PassMap. The following is the complete procedure:

1. The user inputs his account in the graphical user interfaces provided by PassMap.
2. The user tries to click the 2 points selected in the registration phase. The user can shift the world map to his selected areas, zoom in on the map to the specific zoom level, and choose his 2 points. User can zoom out on the map for re-selection or search places directly.
3. PassMap fetches the hashed password of that account received from database, compares it with the hashed password received from the client. If the comparison is identical, this login attempt passes the authentication, otherwise it will be terminated. This completes the login phase.

Resetting Passwords In many situations, users may want to change their passwords. PassMap also provides mechanisms for resetting passwords. First, users should log into PassMap, then they must follow step 2 to step 5 in the registration phase. They will have a new password after doing so.

Another consideration is that users may forget their passwords. Many solutions have been proposed. For example, users can reset their passwords by answering their personal questions or receive new passwords sent from systems via the e-mail addresses recorded during registration. All of these mechanisms are suitable to be implemented with PassMap.

4. IMPLEMENTATION AND USER STUDY

We implemented a prototype of PassMap graphical-password authentication system, and conducted a user study.

4.1 Implementation

We built a website as a prototype of our PassMap. Users can connect to the system to register accounts and log into websites via web browsers. In the scheme mentioned above, the world map data should be stored on the server of PassMap, and clients request the parts of the world map. However, for convenience, we directly used the world map provided by Google Maps. On the client side of our implementation, we used JavaScript and Google Maps API to fetch the real-time world map data and implement drag, zoom in, zoom out, and search functions in the web browsers.

In our prototype, we embedded a 640×420 pixel frame block for displaying the world map in a web page. The initial size of world map is at zoom level 8 of Google Maps, i.e., $2^{16} \times 2^{16}$ pixel, and the center is at Taiwan. We overwrote the zoom in and zoom out functions of Google Maps API, in order to reduce operation time, from zoom level 8, 12, 16 to 18. The search function will shift the map to specific areas and set the zoom level to level 18 directly. Our passwords space is a $2^{26} \times 2^{26}$ pixel image with zoom level 18 of Google Maps. Furthermore, we used satellite-type map instead of road map to increase information objects which users can select as passwords.

4.2 User Study

We introduce our user study including the design, participants, and procedures to evaluate the accuracy and usability of PassMap.

Design In the user study, we want to test two things about PassMap: the first is the users' recollection, which is a user's ability to remember his passwords after a time period; the second is the usability of PassMap, including total time exhausted and the number of functions which are used to control the world map. The usability indicates that whether users are difficult or time-consuming to use PassMap.

In order to analyze the users' recollection, participants must first register for accounts using PassMap and try to log into the system one week later. We divide the usages of PassMap into three phases in this user study: the registration phase, the confirmation phase and the login phase. In the registration phase, participants create accounts and passwords using PassMap. We measure the total time and the number of drag, zoom ins, zoom outs, and searches used in this phase. Furthermore, we also record the participants' birthplaces and residences for later analysis. We then define a login or confirmation attempt so that participants can try to login or confirm their accounts unless they fail six times. If they failed to login after six times in an attempt, this attempt will be marked as failed. In the confirmation/login phase, participants have one confirmation/login attempt. We also record the total time, the number of drags, zoom ins, zoom outs and search functions used and the number of failures given one confirmation/login attempt. Moreover, in order to test recollection after a long time period, we asked participants to do third test after six weeks without any previous notification. We believe that third test will reflect the users' true behaviors and recollection because they are given no notification or preparation. In the third test, participants also have one login attempt.

Participants There are a total of 27 participants (9 females and 18 males) in the first and second tests. All are students of an university. However, because of no previous notification, only 19 participants returned to do the third test. In the user study, we required participants to be experienced computer users and surf the Internet frequently. The education level of the participants vary from Ph.D. student to students pursuing their Bachelor's degree. 21 of the participants majored in computer science. The average age is 23.96 years ($SD = 3.09$), and the range is from 19 to 32.

5. COLLECTED RESULTS

We analyze the data collected in the user study mentioned

above. Accuracy is measured by the success rate of confirmation/login after one week and six weeks. We use this result to make conclusion about users' password recollection. Usability is measured by the total time and the number of functions used in every phase of the user study. Based on this data, we think that PassMap is suitable to build and use in practice.

5.1 Accuracy

Table 1: The accuracy of confirmation/login phases in three tests.

	First Test		Second Test		Third Test	
	First	Total	First	Total	First	Total
Confirmation	96.30%	100%	-	-	-	-
Login	91.77%	100%	76.54%	92.59%	54.72%	81.13%

In order to analyze user recollection in our experiment, we define first accuracy and total accuracy. First accuracy means that a user is successful to login in the first attempt. Total accuracy means that a user is successful to login within six attempts. Table 1 shows the first accuracy and total accuracy of the confirmation/login phase of the three tests. It is clear that both first and total accuracy in the first test are high. After one week, the first accuracy in the second test drops to 76.54%, but the total accuracy is still 92.59%. We analyzed failed submissions in the second test and discovered that participants did not forget their passwords. Most of them still remember the positions of click-points of passwords; however, the points they chosen are very closed to click-points of passwords but not within the tolerance squares, or they got confused by the multiple sets of accounts and passwords, but most of them can log into the system eventually after a few tries. Hence, if we increase the size of tolerance squares to 30×30 pixel, the total accuracy of login phase in second test will become from 92.59% to 98.77%. However, it will also decrease the security strength of PassMap, but we think it is still secure enough (discussed in Section 6 later). Moreover, even after a long time period (six weeks), the total accuracy in third test is still 81.13%.

In summary, we think that the passwords of PassMap are easy for humans to memorize, even after a long time period. On average users can log into the system within 1.37 and 1.65 login submissions with the total accuracy of login being 92.59% and 81.13% after one week and six weeks respectively, even with multiple sets of accounts and passwords.

5.2 Usability

We measure the total time and the number of functions used per login submission to understand the usability of PassMap in practice.

The total time of registration is a little bit long (87.34 seconds on average), but we think it is acceptable. The reason is because users must spend time to think about areas to select click-points from, and then try to manipulate the world map to those areas. The total time in the confirmation phase and the login phase in first test are 35.30% and 30.62% of that in registration phase, i.e., 2.83 and 3.26 times faster, and the trend of the number of functions used is also similar (see Table 2). This is the advantage of using the world map

as the extremely huge passwords space. After one week, the total time and the number of functions used in login phase in second test is slightly more than those in login phase in first test because it takes time to recall passwords, but the total time is still 49.09% of the registration.

Table 2: The total time and the number of functions used in confirmation/login phase.

	Confirmation(1st)			Login(1st)			Login(2nd)		
	Mean	Median	S.D	Mean	Median	S.D	Mean	Median	S.D
Total Time(s)	40.01	37.54	19.96	34.70	33.29	19.97	55.64	52.45	70.31
Zoom Out	1.99	1	2.50	1.91	0	2.58	1.97	0	2.58
Zoom In	0.31	0	0.77	0.24	0	0.72	0.24	0	0.67
Search	1.53	2	0.82	1.52	2	0.84	1.73	2	1.18
Drag	5.85	4	8.60	5.39	3	9.14	6.32	4	6.78

In summary, we think that PassMap is friendly to use in practice. Although users must spend more time to create their passwords, they can confirm or log into the system faster (between 34.7s and 55.64s) based on their knowledge about the world map one week later. We think the results are acceptable because clicking 2 points in a $2^{26} \times 2^{26}$ pixel large image and using functions to manipulate the world map are optimized. Furthermore, the numbers of each functions is used is very low and stable in both confirmation and login phases. This shows that users can easily manipulate the world map to preferred areas and use the system with ease once the click-points have been decided. Hence, we think that PassMap is suitable to build and use in practice.

6. SECURITY ANALYSIS

Brute Force Attacks In order to quantify the security of PassMap against brute force attacks, we calculate the entropy of password in PassMap. Entropy means the quantity of information inside the password space, i.e., all possible passwords, in bits. If the entropy of a password space is x bits, there will be 2^x possible passwords in that space.

In our implementation, the size of the world map is $2^{26} \times 2^{26}$ pixel, and the tolerance squares are 20×20 pixel. However, we think that the oceans look about the same in the world map, and no participants selected click-points in the ocean in the user study, so we exclude ocean. Hence, the image size becomes $2^{26} \times 2^{26} \times 0.2905$ pixel (about 29.05% of Earth is land). We then measure the security strength of PassMap with entropy.

Table 3: The entropy (bits) of PassMap and corresponding length of text passwords, compared with PassPoints.

sequential click-point(s)	PassMap					PassPoints
	1	2	3	4	5	5
Entropy of 20×20 (bits)	41.57	83.14	124.72	166.29	207.86	43
Length of Text Passwords	6.35	12.69	19.04	25.39	31.37	6.56
Total Accuracy	-	92.59%	-	-	-	94%

Table 3 shows the entropy of PassMap against brute force attacks and corresponding length of text passwords with 20×20 pixel wide tolerance squares, varied from 1 to 5 sequential click-point(s), compared with PassPoints [12][1][9]. We can find that even with only 1 click-point, the security strength of PassMap is closed to that of PassPoints with 5 click-points, which is approximately equal to the strength

of a 6 textual passwords. With our proposed 2 click-points scheme, the entropy is 83.14 bits, which is approximately equal to a 12 textual password. We think this is more secure than most graphical-password authentication systems in practice against brute force attacks [1].

Pattern Dictionary Attacks Just like other cued-recall based systems, PassMap is still vulnerable to the threat of pattern dictionary attacks. Attackers can collect the image of the world map and perform image processing [4] to obtain hotspots and patterns. However, we increase the cost of pattern dictionary attacks greatly, making it more difficult because of the time and computing power available in practice. Compared to PassPoints with 451×331 pixel wide image, the image size of PassMap, $2^{26} \times 2^{26}$ pixel, is 3.02×10^{10} times larger. Even when we exclude the parts of the ocean, it is still about 8.76×10^9 times larger than the image of PassPoints. Hence, the cost of processing the whole image of PassMap is extremely high.

However, in order to memorize the passwords more easily, users may choose the click-points near one's birthplaces or residences. Hence, attackers can decrease the image size to be processed and lower attack cost by collecting personal information about users. We think that this is the trade-off between security and users' recollection. However, compared to PassPoints, the cost for attackers is still high because although users choose birthplaces or residences as their passwords, the map size (i.e., password space) is still large. Moreover, attackers must do additional effort to collect the personal information about users or the list of famous landscapes. We also measured the distance between the 2 click-points in a password. On average they were 3198227.4 pixel apart, which is equal to 4997.23 frame blocks. This means the distance between 2 click-points of a password is quite large, which also increases the cost for attackers.

Limitation Shoulder-surfing attack is a direct attack focused on the visual aspect of graphical passwords. When users are logging in or inputting passwords, attackers may directly observe or use external recording devices such as high resolution cameras and surveillance equipments [6] to collect users' credentials. PassMap is not resistant to shoulder-surfing attack, but it decreases the probability of successful attacks and increases the cost for attackers when compared with PassPoints. It is difficult for attackers to know where these areas are or how to use the map functions to shift the map to these areas by the small parts displayed unless attackers record the entire authentication process.

7. CONCLUSION

In order to solve the password recollection and security problems of PassPoints, we propose a novel world map based graphical-password authentication system called PassMap. By using an extremely huge world map image as the password space, and a sequence of 2 click-points that user selects in an huge world map as the password. We implemented a prototype of PassMap and conducted a user study. The collected results shows that after a week, the accuracy of login is 92.59%. The accuracy of PassMap is higher than that of PassPoints. Moreover, even after a long time period (six weeks), the accuracy of login is still 81.13%. The total time of login is on average between 34.7s and 55.64s.

PassMap provides 83.14 bits entropy against brute force attacks, much higher than the 43 bits provided by Pass-

Points, even when we exclude the oceans. Moreover, the image size of PassMap is 3.02×10^{10} times larger than that of PassPoints. PassMap increases the cost of pattern dictionary attacks greatly because of time and computing power available in practice, even though there are still hotspots on the world map. We conclude that PassMap is a secure and friendly cued-recall based graphical-password authentication system with easy-to-remember passwords for humans.

8. REFERENCES

- [1] R. Biddle, S. Chiasson, and P. van Oorschot. Graphical passwords: Learning from the first twelve years. *ACM Computing Surveys (to appear)*. School of Computer Science, Carleton University, 2010.
- [2] G. Blonder. Graphical password, Sept. 24 1996. US Patent 5,559,961.
- [3] S. Chiasson, A. Forget, E. Stobert, P. Van Oorschot, and R. Biddle. Multiple password interference in text passwords and click-based graphical passwords. In *Proceedings of the 16th ACM conference on Computer and communications security*, pages 500–511. ACM, 2009.
- [4] A. Dirik, N. Memon, and J. Birget. Modeling user choice in the passpoints graphical password scheme. In *Proceedings of the 3rd symposium on Usable privacy and security*, pages 20–28. ACM, 2007.
- [5] I. Jermyn, A. Mayer, F. Monroe, M. K. Reiter, and A. D. Rubin. The design and analysis of graphical passwords. In *Proceedings of the 8th conference on USENIX Security Symposium-Volume 8*, pages 1–1. USENIX Association, 1999.
- [6] B. Laxton, K. Wang, and S. Savage. Reconsidering physical key secrecy: Teleduplication via optical decoding. In *Proceedings of the 15th ACM conference on Computer and communications security*, pages 469–478. ACM, 2008.
- [7] D. Nelson, U. Reed, and J. Walling. Picture superiority effect. *Journal of Experimental Psychology: Human Learning and Memory*, 3:485–497, 1977.
- [8] A. Perrig and D. Song. Hash visualization: A new technique to improve real-world security. In *International Workshop on Cryptographic Techniques and E-Commerce*, pages 131–138. Citeseer, 1999.
- [9] X. Suo, Y. Zhu, and G. Owen. Graphical passwords: A survey. 2005.
- [10] J. Thorpe and P. Van Oorschot. Towards secure design choices for implementing graphical passwords. 2004.
- [11] J. Thorpe and P. van Oorschot. Human-seeded attacks and exploiting hot-spots in graphical passwords. In *Proceedings of 16th USENIX Security Symposium on USENIX Security Symposium*, pages 8:1–8:16. USENIX Association, 2007.
- [12] S. Wiedenbeck, J. Waters, J. Birget, A. Brodskiy, and N. Memon. Passpoints: Design and longitudinal evaluation of a graphical password system. *International Journal of Human-Computer Studies*, 63(1-2):102–127, 2005.
- [13] S. Wiedenbeck, J. Waters, L. Sobrado, and J. Birget. Design and evaluation of a shoulder-surfing resistant graphical password scheme. In *Proceedings of the working conference on Advanced visual interfaces*, pages 177–184. ACM, 2006.